



CLOUD SECURITY · AI SECURITY

Cloud + AI Pipeline Security Assessment

Assessment of a small AWS-hosted machine learning training and inference pipeline, using CIS AWS Benchmark-aligned automated scanning (Prowler) and manual least-privilege review — with every remediation independently verified, not assumed.

Muhammad Anas
CLOUD & AI SECURITY

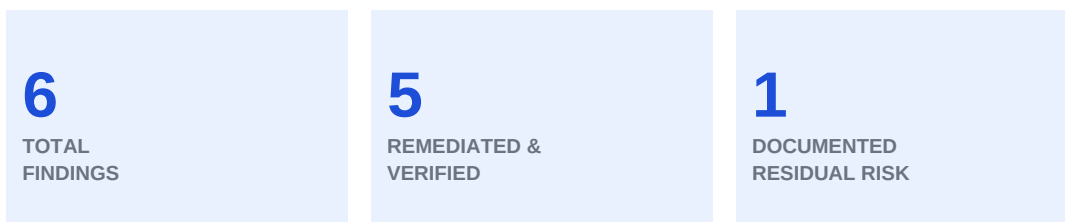
Portfolio Assessment Project
Scope: 1 S3 bucket · 1 EC2 instance · 1 IAM role

OVERVIEW

Executive Summary

A security assessment of a small AI training pipeline hosted on AWS identified three critical risk areas: publicly accessible training data, an internet-exposed model endpoint with no authentication, and an over-permissioned service role. If exploited, these gaps could result in unauthorized access to training data, unrestricted use of the deployed model, and lateral movement within the AWS account beyond what the training workload requires.

Five of six findings were fully remediated and confirmed via a repeat scan. The sixth (EC2 public IP) was assessed and knowingly deferred as a documented residual risk, given the scope and cost/benefit of a full network redesign for a demo environment — a judgment call consistent with how a real engagement would be prioritized.



Top priorities addressed

- Restricted the S3 bucket — training data is no longer publicly downloadable
- Locked down the model endpoint — no longer reachable by anyone on the internet
- Scoped the IAM role to least privilege — no more account-wide S3 access

Findings

FINDING 1

HIGH

REMIEDIATED — PASS

S3 bucket had Block Public Access disabled (account and bucket level)

Business impact. Training data — including a file named confidential.csv — was publicly downloadable by anyone with the bucket name or object URL. Direct data exposure risk with no access control or audit trail.

Remediation. Enabled Block Public Access at both account and bucket level.

Framework reference. CIS AWS 1.20 · ISO/IEC 27001 A.5.15 · MITRE ATLAS AML.T0025 (Exfiltration via Cyber Means)

FINDING 2

HIGH

REMIEDIATED — PASS

EC2 security group allowed unrestricted inbound access to the model inference port and SSH, with no authentication on the API

Business impact. Anyone on the internet could query the model endpoint at unlimited volume with no authentication, rate limiting, cost control, or usage trail; SSH was similarly open to brute-force / credential-stuffing attempts.

Remediation. Restricted both inbound rules (port 5000 and port 22) from 0.0.0.0/0 to a single trusted IP.

Framework reference. CIS AWS 5.2 · NIST CSF Protect · MITRE ATLAS AML.T0044 (Full ML Model Access)

FINDING 3

MEDIUM

DOCUMENTED RESIDUAL RISK

EC2 instance retains a public IP address

Business impact. Unnecessarily increases attack surface — a training workload has no legitimate need for direct internet exposure.

Remediation. Deferred: full removal requires a VPC redesign (private subnet + NAT gateway). Documented as an accepted residual risk given demo scope, rather than over-engineering a network rebuild for a portfolio exercise.

Framework reference. CIS AWS 5.4 · NIST CSF Protect

FINDING 4

HIGH

REMEDIATED — PASS

IAM role held full account-wide S3 access and failed cross-service confused-deputy protection

Business impact. If the EC2 instance were compromised, the attacker would inherit full S3 access across the entire AWS account — not just the training bucket — violating least privilege. The role's trust policy also had no source-account condition, a separate confused-deputy risk from the permissions themselves.

Remediation. Replaced AmazonS3FullAccess with a custom policy scoped to s3:GetObject on the training bucket only, and added an aws:SourceAccount condition to the role's trust policy.

Framework reference. CIS AWS 1.16 · ISO/IEC 27001 A.5.15 · NIST AI RMF Manage

Note on Finding 4. Prowler's automated "administrative privileges" check did not originally flag this role as high-risk, since AmazonS3FullAccess is service-scoped rather than full account admin. Manual review against the least-privilege principle identified it as a real risk regardless: the training job only needed read access to one bucket, not write/delete access across every S3 bucket in the account. This is the kind of gap automated scanning alone misses, and where manual assessment adds value beyond the tool.

VALIDATION

Verification: Before & After

Every remediation below was confirmed by re-running Prowler, not assumed from the configuration change alone.

PROWLER CHECK ID	BEFORE	AFTER
s3_account_level_public_access_blocks	FAIL	PASS
s3_bucket_level_public_access_block	FAIL	PASS
ec2_securitygroup_allow_ingress_from_internet_to_any_port	FAIL	PASS
ec2_securitygroup_allow_ingress_from_internet_to_high_risk_tcp_ports	FAIL	PASS
ec2_instance_port_ssh_exposed_to_internet	FAIL	PASS
iam_role_cross_service_confused_deputy_prevention	FAIL	PASS
ec2_instance_public_ip	FAIL	FAIL (deferred)

NEXT STEPS

Remediation Roadmap

Completed — same day, near-zero cost

- Enabled Block Public Access at both account and bucket level
- Restricted the security group: removed 0.0.0.0/0 on the inference port and SSH, scoped to a single trusted IP
- Replaced AmazonS3FullAccess with a custom least-privilege policy scoped to the training bucket
- Added an aws:SourceAccount condition to the role's trust policy to close the confused-deputy gap

Deferred — documented residual risk

- Public IP on the training instance: full remediation requires moving to a private subnet with a NAT gateway for outbound package installs — a network redesign judged disproportionate to the risk for a demo-scoped environment. Flagged here so it is not silently accepted.

Cost / effort estimate

All completed fixes were configuration-only — no new infrastructure required. Actual engineering effort: under 2 hours, effectively \$0 in additional AWS spend. This should be weighed against the cost of a real data-exposure incident (breach notification, investigation, and potential regulatory exposure if the affected data were real customer PII) when framing the return on remediation effort to stakeholders.

GOVERNANCE

Framework Coverage

Findings map to the following recognized frameworks, demonstrating alignment with both technical benchmarks and governance standards.

FINDING	CIS AWS	NIST CSF	ISO 27001	MITRE ATLAS	NIST AI RMF
1. Public S3 bucket	✓		✓	✓	
2. Exposed endpoint / SSH	✓	✓		✓	
3. Public IP on instance	✓	✓			
4. Overprivileged IAM role	✓		✓		✓

Scope note: this assessment was limited to the resources listed above. The AWS account was not hardened for broader compliance frameworks (GDPR, HIPAA, PCI-DSS, etc.), which fall outside the scope of this exercise.

APPENDIX

Evidence

FINDING 1 — S3 PUBLIC ACCESS

Before: Block Public Access off

The screenshot shows the AWS IAM console interface for the bucket 'cloud-security-project-demo-bucket'. The 'Permissions' tab is selected. Under 'Block public access (bucket settings)', the 'Block all public access' toggle is set to 'Off' with a yellow warning triangle icon. Below this, there is a link to 'Individual Block Public Access settings for this bucket'.

S3 bucket permissions — Block all public access: Off

After: Block Public Access on

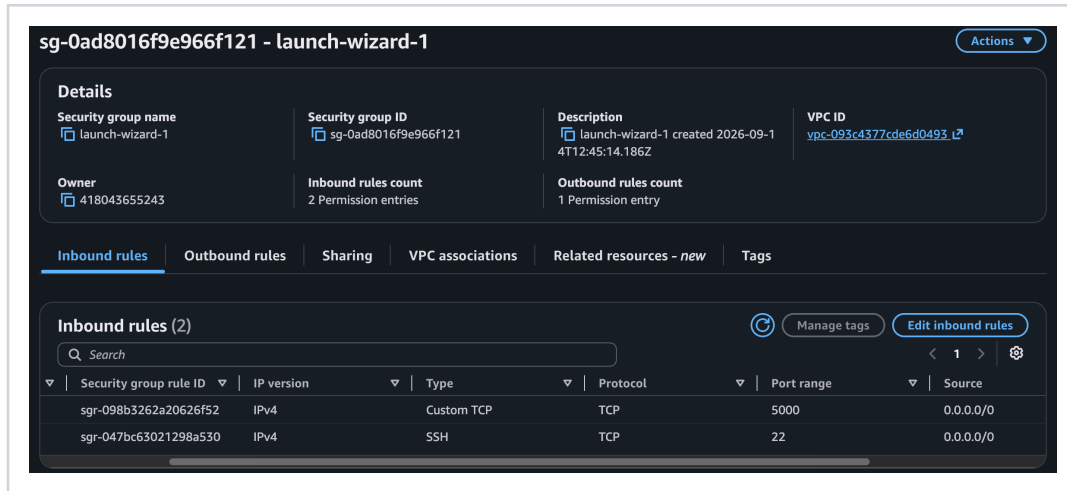
The screenshot shows the same AWS IAM console interface, but the 'Block all public access' toggle is now 'On' with a green checkmark icon. Below this, the 'Individual Block Public Access settings for this bucket' section is expanded, showing four sub-settings, all of which are checked (enabled):

- ☒ **Block public access to buckets and objects granted through new access control lists (ACLs)**
S3 will block public access permissions applied to newly added buckets or objects, and prevent the creation of new public access ACLs for existing buckets and objects. This setting doesn't change any existing permissions that allow public access to S3 resources using ACLs.
- ☒ **Block public access to buckets and objects granted through any access control lists (ACLs)**
S3 will ignore all ACLs that grant public access to buckets and objects.
- ☒ **Block public access to buckets and objects granted through new public bucket or access point policies**
S3 will block new bucket and access point policies that grant public access to buckets and objects. This setting doesn't change any existing policies that allow public access to S3 resources.
- ☒ **Block public and cross-account access to buckets and objects through any public bucket or access point policies**
S3 will ignore public and cross-account access for buckets or access points with policies that grant public access to buckets and objects.

S3 bucket permissions — Block all public access: On, all four sub-settings enabled

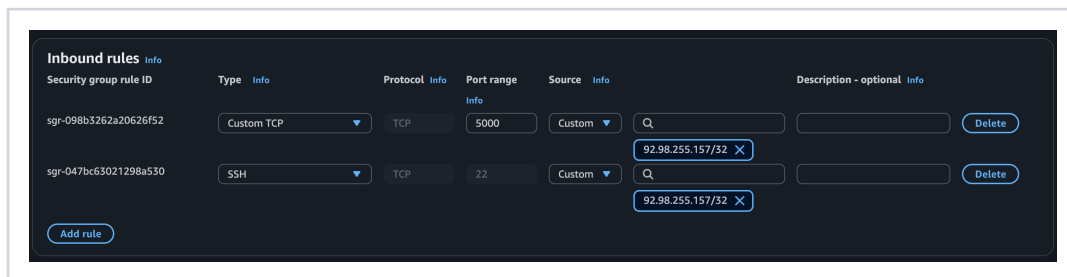
FINDING 2 — EXPOSED ENDPOINT & SSH

Before: inbound rules open to the internet



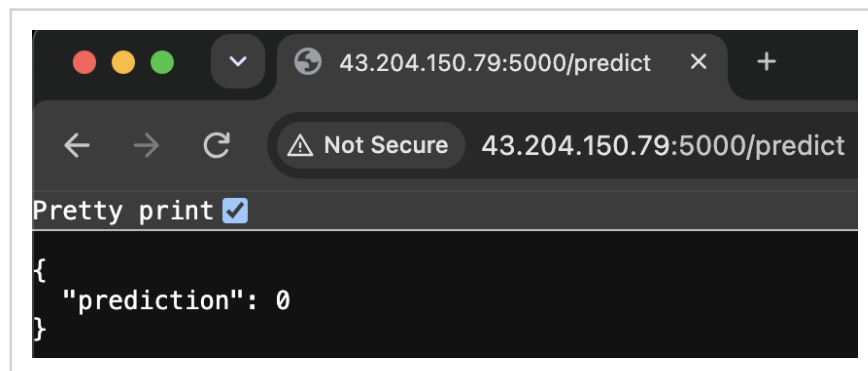
Security group sg-0ad8016f9e966f121 — port 5000 and port 22, both open to 0.0.0.0/0

After: inbound rules restricted



Same security group — both rules restricted to a single trusted IP (92.98.255.157/32)

Proof of exposure (captured before remediation)



Unauthenticated JSON response from the model endpoint, accessed externally via public IP

FINDING 4 — OVERPRIVILEGED IAM ROLE

Role permissions before remediation

ml-training-role-overprivileged Info Delete

Role attached to EC2 instance running the ML training pipeline for the Cloud + AI Security Audit portfolio project. Grants S3 access so the training script can read the dataset bucket. NOTE: Intentionally over-permissioned with AmazonS3FullAccess (full account-wide S3 access) instead of scoped access to a single bucket, this is a deliberate misconfiguration for security assessment purposes, to be identified and remediated during the Prowler scan and reported in the findings.

Summary Edit

Creation date
September 14, 2026, 17:29 (UTC+04:00)

ARN
arn:aws:iam::418043655243:role/ml-training-role-overprivileged

Instance profile ARN
arn:aws:iam::418043655243:instance-profile/ml-training-role-overprivileged

Last activity
29 minutes ago

Maximum session duration
1 hour

Permissions Trust relationships Tags Last Accessed Revoke sessions

Permissions policies (2) Info Simulate Remove Add permissions

You can attach up to 20 managed policies.

Filter by Type
All types

☐	Policy name	Type	Attached entities
☐	AmazonS3FullAccess	AWS managed	1
☐	SecurityAudit	AWS managed - job function	1

ml-training-role-overprivileged — AmazonS3FullAccess attached (full account-wide S3 access)

Scoped policy applied after remediation

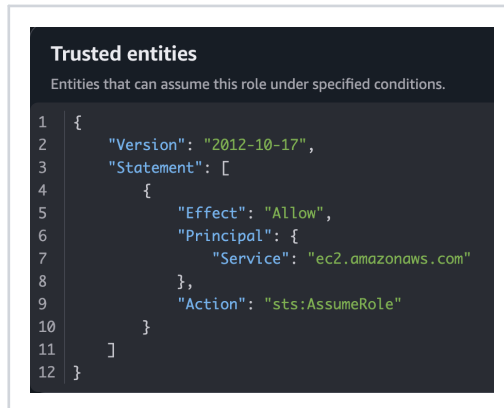
Permissions defined in this policy Info Copy Edit Summary JSON

Permissions defined in this policy document specify which actions are allowed or denied. To define permissions for an IAM identity (user, user group, or role), attach a policy to it

```
1 {
2   "Version": "2012-10-17",
3   "Statement": [
4     {
5       "Effect": "Allow",
6       "Action": [
7         "s3:GetObject"
8       ],
9       "Resource": "arn:aws:s3:::cloud-security-project-demo-bucket/*"
10    }
11  ]
12 }
```

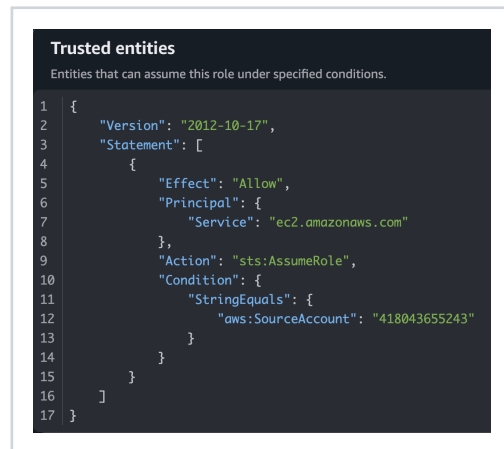
Least-privilege replacement policy — read-only access (s3:GetObject) scoped to the training bucket only

Trust policy before remediation (no source-account condition)



Trust policy — no condition restricting which account can assume the role

Trust policy after remediation



Trust policy — aws:SourceAccount condition added, closing the confused-deputy gap

Prepared as part of a cloud and AI security portfolio project. Assessment methodology combined automated scanning (Prowler, CIS AWS Benchmark) with manual least-privilege review to surface risks that automated tooling alone did not flag as critical, and every remediation was independently verified via a repeat scan rather than assumed.